

YESAYA PASARIBU

Penetration Tester • Web, Mobile & API Security • OSCP • CEH

Bekasi, Indonesia | +62 813-3481-3532 | carerra2804@gmail.com

HackerOne: hackerone.com/narexsh | LinkedIn: linkedin.com/in/yesayapasaribu

Open to Onsite, Remote & Relocation — Worldwide

PROFESSIONAL SUMMARY

OSCP- and CEH-certified Penetration Tester with 3+ years of hands-on security research, specializing in web, Android, and API security. Verified bug bounty researcher on HackerOne and the Google Vulnerability Reward Program (VRP), with triaged reports and paid bounties for vulnerabilities in production systems — including a #1 ranking on a private, invite-only HackerOne program. Proven track record of responsible disclosure across 15+ enterprise targets in automotive, telecom, e-commerce, and enterprise software — including chained Critical findings such as SQL injection, IDOR/BOLA, and Remote Code Execution. Fluent in OWASP Web & Mobile Top 10, with end-to-end reporting from PoC to CVSS scoring and remediation. Cum Laude graduate, Top 3% of 830. Seeking Penetration Tester, Red Team, or AppSec roles — onsite or remote.

CORE COMPETENCIES

Web Application Pentesting · Android / Mobile Pentesting · API & WebSocket Security · OWASP Top 10 & Mobile Top 10 · SQL Injection & Injection Attacks · IDOR / BOLA / Broken Access Control · Burp Suite & Intruder · Vulnerability Assessment & Reporting · Responsible Disclosure & PoC Writing · CVSS v3.1 Scoring

CERTIFICATIONS

- **Offensive Security Certified Professional (OSCP)** — OffSec
- **Certified Ethical Hacker (CEH)** — EC-Council
- **Certified Red Team Operations Management (CRTOM)**
- Networking & Security in Google Cloud — Google
- Cloud Computing Fundamentals (GCP) — Google
- System Administration & IT Infrastructure Services

SECURITY RESEARCH & BUG BOUNTY

Bug Bounty Researcher — HackerOne

2021–Present

Public & private programs — web, API & mobile

- **Ranked #1 on a private, invite-only program** — a trust signal reserved for researchers with a proven, high-quality track record.
- Submitted triaged, valid vulnerability reports and earned monetary bounties for confirmed findings on production targets.
- Primary focus: BOLA/IDOR, broken access control, business-logic flaws, and Android/mobile vulnerabilities.
- **Verified track record: HackerOne Reputation 147**, earned from resolved/accepted reports across public & private programs.

Bug Bounty Researcher — Google Vulnerability Reward Program (VRP)

2023–Present

Google Bug Hunters

- Reported multiple security vulnerabilities accepted as valid by Google's Security Team through the VRP, contributing to remediation of production issues.
- Submissions triaged and confirmed across Google products; ongoing active participation.

Independent Security Researcher — Responsible Disclosure

Jan 2023–Present

Self-initiated coordinated disclosure across multiple industries

- Identified and responsibly disclosed vulnerabilities in production web and Android applications for 15+ organizations spanning automotive, telecommunications, e-commerce, and enterprise software.

- All findings documented with full PoC and accepted/acknowledged by the target organizations.

Featured Engagement — Honda Indonesia (HPM): CRM Portal, Private APIs & e-Care Android App *Feb–Mar 2026*

Web Application Findings

- **[CRITICAL]** Boolean-based SQL Injection — bypassed authentication on an announcement endpoint to access 20,000+ cross-dealer records (CWE-89, OWASP A03:2021).
- **[CRITICAL]** IDOR — mass admin credential disclosure via the contact-agents API; extraction automated with Burp Intruder (CWE-639, OWASP A01:2021).
- **[CRITICAL]** BOLA — full customer PII exposure on profile endpoints through parameter tampering (CWE-639, OWASP A01:2021).
- **[HIGH]** Cross-Site WebSocket Hijacking — session hijack and cross-dealer data exfiltration.
- **[HIGH]** IDOR via WebSocket — agent PII disclosure across dealer entities.
- **[HIGH]** Broken Function-Level Authorization — national customer database extraction.

Android Application Findings (Honda e-Care)

- **[CRITICAL]** RCE via Malicious APK Backdoor — injected a Meterpreter reverse shell to achieve full device compromise: arbitrary command execution, file access, system enumeration (CWE-94, CWE-494, OWASP Mobile M8).
- **[HIGH]** Insecure CORS with Credential Support — cross-origin data theft.

Delivered professional reports with executive summary, CVSS v3.1 scoring, step-by-step PoC, and remediation guidance. Full reports available upon request under NDA.

Additional Research

- Self-directed web/Android assessments: SQLi, XSS, IDOR, SSRF, OS command injection, business-logic, and insecure data storage (OWASP Top 10 / Mobile Top 10).
- SOC simulation: log monitoring, incident detection, and threat correlation using Wazuh, SIEM, Wireshark, and Linux log analysis.

PROFESSIONAL EXPERIENCE

Cloud Computing Cohort Student — Bangkit Academy

Feb–Aug 2024

Led by Google, GoTo (Gojek/Tokopedia) & Traveloka

- Selected for one of Indonesia's most competitive tech acceleration programs; curriculum in cloud-native development and security.
- Completed intensive GCP training: IAM, VPC, firewall configuration, and secure API deployment; deployed scalable backends on Compute Engine, Cloud Run, and Cloud Storage.
- Applied cloud security principles — least-privilege access, network segmentation, and threat monitoring — in a production-ready capstone project.

Data Analyst Intern — Telkomsel

Aug–Sep 2024

Indonesia's largest telecommunications operator

- Performed data processing, cleaning, and validation with SQL to support daily operational reporting at enterprise scale.
- Prepared routine data summaries and visual reports supporting data-driven decisions across operational teams.

Cybersecurity Intern — Multimedia, Big Data & Cybersecurity Lab

Jul–Sep 2023

Telkom University

- Built 3D interactive models and gamified security simulations (Unity, Blender) for cybersecurity education and awareness.
- Contributed to research on security visualization, system modeling, and immersive technology in security training.

Freelance Web Developer — Self-Employed

Jul 2022–Jan 2023

- Built responsive, production-ready web apps with Vue.js, TailwindCSS, and Node.js; translated Figma designs into polished interfaces.
- Managed the full project lifecycle: requirements, implementation, REST API integration, testing, and deployment.

EDUCATION

B.Eng, Telecommunication Engineering — Telkom University

Aug 2021–Nov 2025

- GPA 3.64 / 4.00 — Cum Laude, Top 21 of 830 graduates (~Top 3%); Paragon Scholarship Awardee (1 of 10 from 5,000+ applicants).
- Relevant coursework: Network Security, Cloud Infrastructure, Cryptography, Data Communication, Programming Logic.

TECHNICAL SKILLS

Security Tools: Burp Suite & Intruder, OWASP ZAP, Kali Linux, Metasploit, Wireshark, Wazuh, ADB

Vulnerabilities: SQLi, IDOR, BOLA, XSS, SSRF, CSRF, RCE, WebSocket Hijacking, CORS Misconfiguration, Broken Access Control

Mobile Security: APK analysis, reverse engineering, insecure data storage, log leakage, OWASP Mobile Top 10

Programming: Python, JavaScript, SQL, Bash, HTML/CSS, MATLAB

Cloud & Frameworks: GCP (Compute Engine, Cloud Run, Cloud Storage), Node.js, Vue.js, TailwindCSS

Databases / VCS: MySQL, PostgreSQL, SQLite | Git & GitHub

LANGUAGES

Bahasa Indonesia — Native / Bilingual · English — Professional Working Proficiency

AWARDS & RECOGNITION

- Paragon Scholarship (2023–2025) — selected as 1 of 10 from 5,000+ national applicants for academic and leadership excellence.
- Cum Laude Graduate, Telkom University (2025) — awarded to 21 of 830 graduates; Top ~3% of cohort, GPA 3.64/4.00.